- Students will perform security posture assessment
- Students will use OSINT to gather information
- Students will use Google dorks for performing various operations
- Students will use shodan.io for analysis

Students will perform security posture assessment

1. **Defining Scope and Objectives**
   Purpose: Establish boundaries and expectations before any technical activity.
    - Practical Actions
        - Identify assets in scope:
            - Servers (Windows/Linux)
            - Network devices (firewalls, routers, switches)
            - Applications (web, internal apps), Cloud resources (if applicable)
        - Define assessment type:
            - Configuration review
            - Vulnerability assessment
            - Compliance assessment
            - Full security posture assessment
2. **Asset Discovery and Inventory**
   Purpose: You cannot secure what you do not know.
    - Practical Actions
        - Identify live assets using:
            - nmap -sn <network-range>
            - Active Directory computer objects
            - Cloud dashboards
        - Classify assets:
            - Critical / Non-critical
            - Production / Test / Dev
    - Tools
        - Nmap, Active Directory
        - CMDB / Excel
        - Cloud inventory tools
3. **Baseline Security Controls Review**
   Purpose: Measure current controls against best practices.
   - Areas to Review
        - Authentication & Authorization
        - Patch management
        - Backup & recovery
        - Logging & monitoring
        - Network segmentation
   - Practical Checks
        - Password policy in AD (secpol.msc → local password policy editor.)
        - Firewall rules review (Palo Alto / Windows Firewall)
        - Antivirus/EDR presence
        - Backup schedules and restore testing

4. **Configuration Assessment (Hardening Check)**
   Purpose: Identify insecure system and network configurations.
   Practical Actions
   - Windows
        - Check:
            - RDP restrictions
            - Local admin usage
        - Tools:
            - Microsoft Security Baseline
            - gpresult /r

- Linux
    - Check:
        - SSH root login
        - File permissions
        - Firewall rules (firewalld, iptables)
    - Commands:
        - sudo ss -tuln
        - sudo firewall-cmd --list-all
- Network Devices
    - Default credentials
    - Unused open ports
    - Weak encryption protocols

5. **Vulnerability Assessment**

Purpose: Identify known exploitable weaknesses.
Practical Steps

- Deploy a vulnerability scanner
- Configure scan policy
- Run authenticated scans (preferred)
- Analyze results

Tools

- Nessus, Qualys, OpenVAS

Identify:

- Critical CVEs ((Common Vulnerabilities and Exposures)
- Missing patches
- Weak ciphers

6. **Network Security Assessment**

Purpose: Validate network-level protection.
Practical Checks

- Firewall rule base review
- NAT and segmentation validation
- IDS/IPS status
- Open ports and exposed services
- Commands
    - nmap -sV -p- <target-ip>
    - tracert <destination>

Now Practical:

Lab requirement

- 1 linux server (192.168.88.155/24)
    - Internet active: yes
- 1 windows server (192.168.88.158/24)
    - Internet active: yes
- Using NMAP as CLI for tracing details on linux.
- Installing & Using Nessus web-based tool for gathering information about target.

On linux server:

```
[root@server ~]# nmap -sn 192.168.88.0/24
Starting Nmap 7.92 ( https://nmap.org ) at 2026-01-07 22:49 IST
Nmap scan report for 192.168.88.1
Host is up (0.00036s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.88.2
Host is up (0.00014s latency).
MAC Address: 00:50:56:F4:DC:E9 (VMware)
Nmap scan report for 192.168.88.155
Host is up (0.00018s latency).
MAC Address: 00:0C:29:49:A3:C0 (VMware)
Nmap scan report for 192.168.88.254
Host is up (0.00014s latency).
MAC Address: 00:50:56:FE:45:49 (VMware)
Nmap scan report for 192.168.88.151
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.03 seconds
[root@server ~]#
```

Command

- "-sn" – it checks only hosts are up or not. It sends ICMP echo ping request to port 443.

Scanning port and service using “**nmap -sS -sV -O 192.168.88.155**”

```
[root@server ~]# nmap -sS -sV -O 192.168.88.155
Starting Nmap 7.92 ( https://nmap.org ) at 2026-01-08 11:49 IST
Nmap scan report for 192.168.88.155
Host is up (0.00025s latency).
Not shown: 996 closed tcp ports (reset)
PORT    STATE SERVICE      VERSION
80/tcp  open  http         Microsoft IIS httpd 10.0
135/tcp open  msrpc        Microsoft Windows RPC
139/tcp open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
MAC Address: 00:0C:29:49:A3:C0 (VMware)
Device type: general purpose
Running: Microsoft Windows 2016
OS CPE: cpe:/o:microsoft:windows_server_2016
OS details: Microsoft Windows Server 2016 build 10586 - 14393
Network Distance: 1 hop
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.47 seconds
```

Command:

- “-sS” = tcp syn scan
- “-sV” = version detection
- “-O” = detect OS version

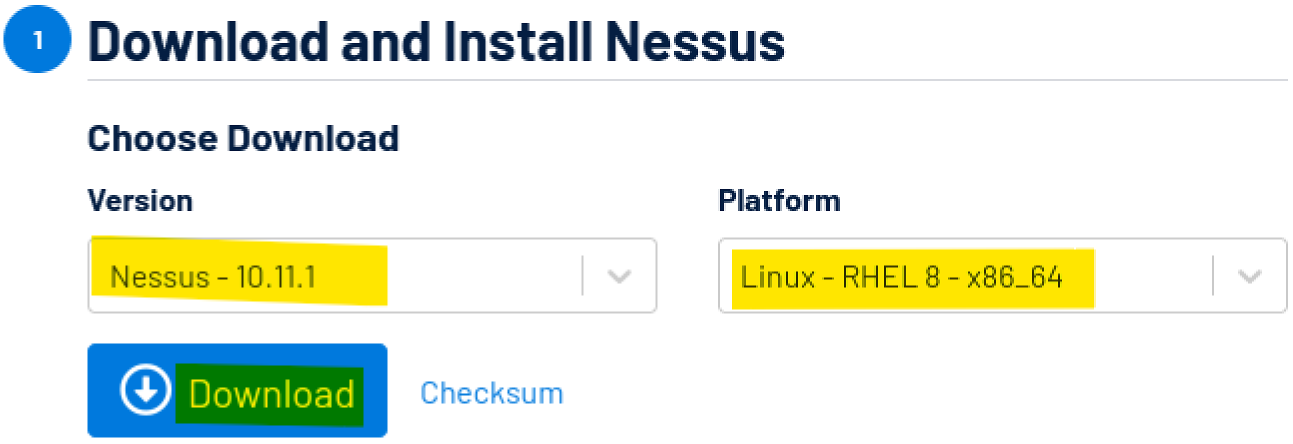
After installing DNS role on Windows server, run same command “**nmap -sS -sV -O 192.168.88.156**”

```
[root@server ~]# nmap -sS -sV -O 192.168.88.155
Starting Nmap 7.92 ( https://nmap.org ) at 2026-01-08 12:13 IST
Nmap scan report for 192.168.88.155
Host is up (0.00034s latency).
Not shown: 995 closed tcp ports (reset)
PORT    STATE SERVICE      VERSION
53/tcp  open  domain       Simple DNS Plus
80/tcp  open  http         Microsoft IIS httpd 10.0
135/tcp open  msrpc        Microsoft Windows RPC
139/tcp open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
MAC Address: 00:0C:29:49:A3:C0 (VMware)
Device type: general purpose
Running: Microsoft Windows 2016
OS CPE: cpe:/o:microsoft:windows_server_2016
OS details: Microsoft Windows Server 2016 build 10586 - 14393
Network Distance: 1 hop
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows
```

Installing Nessus for networking monitoring:

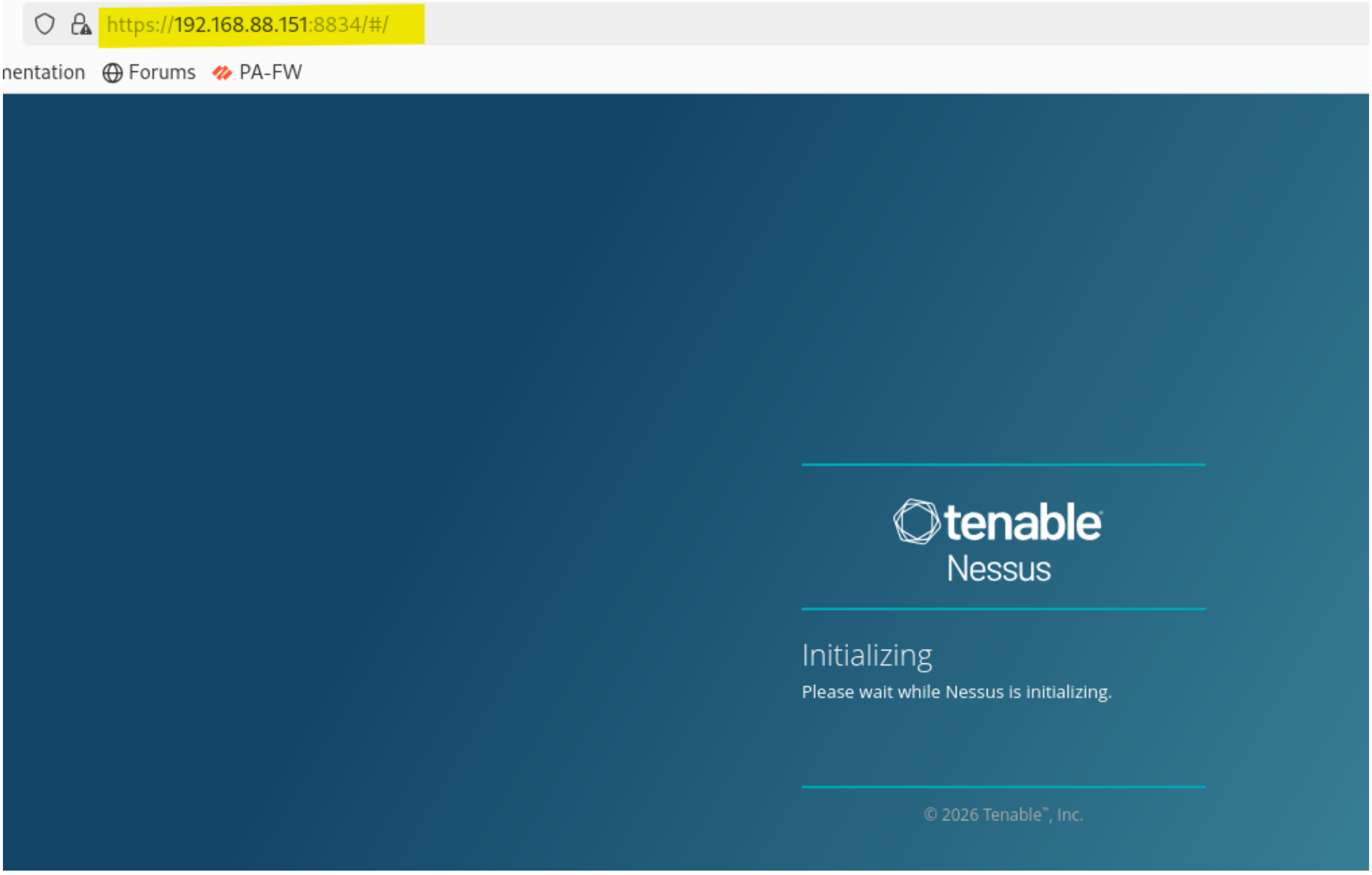
Download link: https://www.tenable.com/downloads/nessus?loginAttempted=true

Selecting correct version:

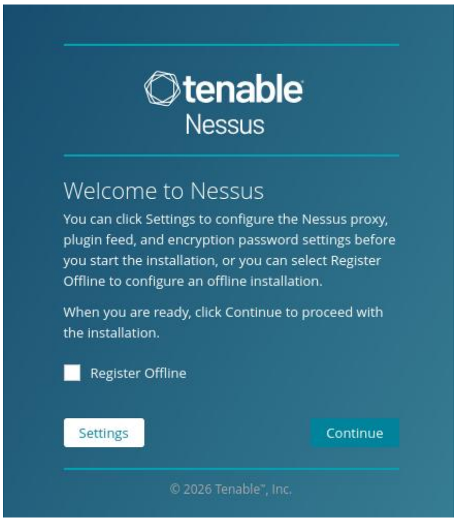


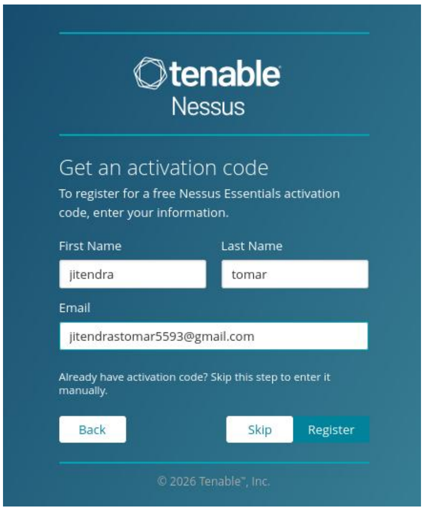
- sudo systemctl start nessusd
- sudo systemctl enable nessusd

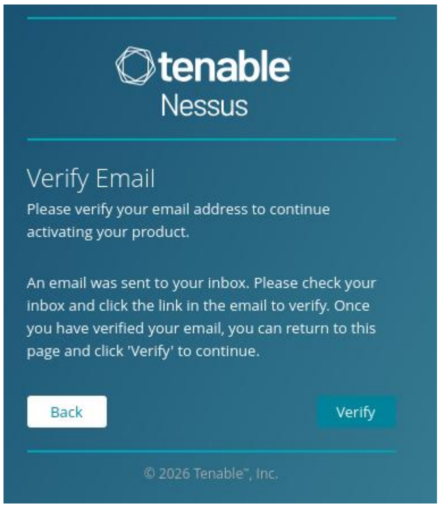
accessing Nessus on firefox https://192.168.88.151:8834/



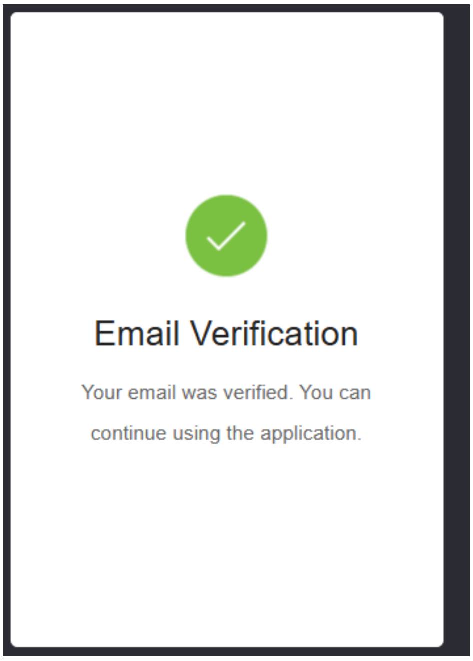
Register Nessus Essential for small network

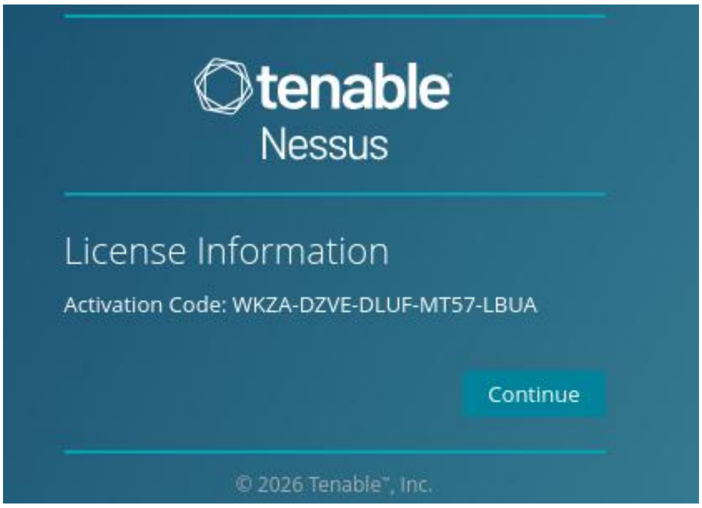




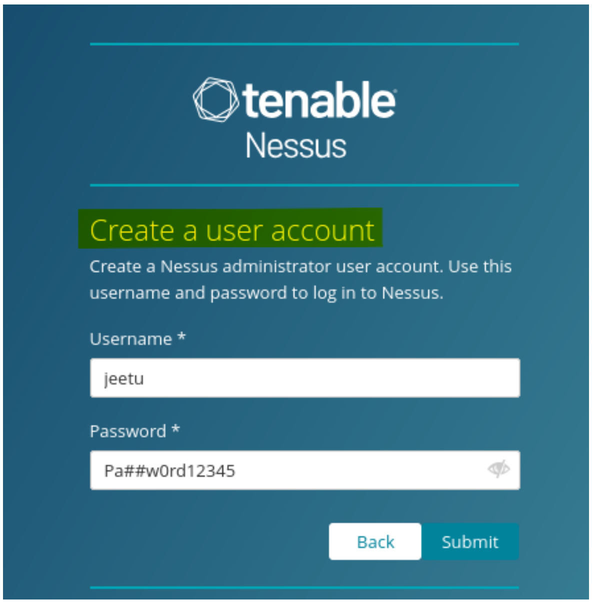


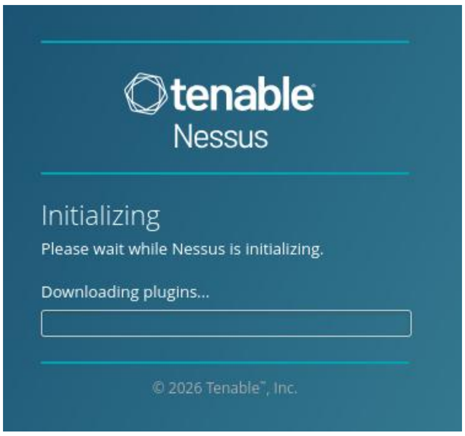
Verify over your email ID and click on verify button.



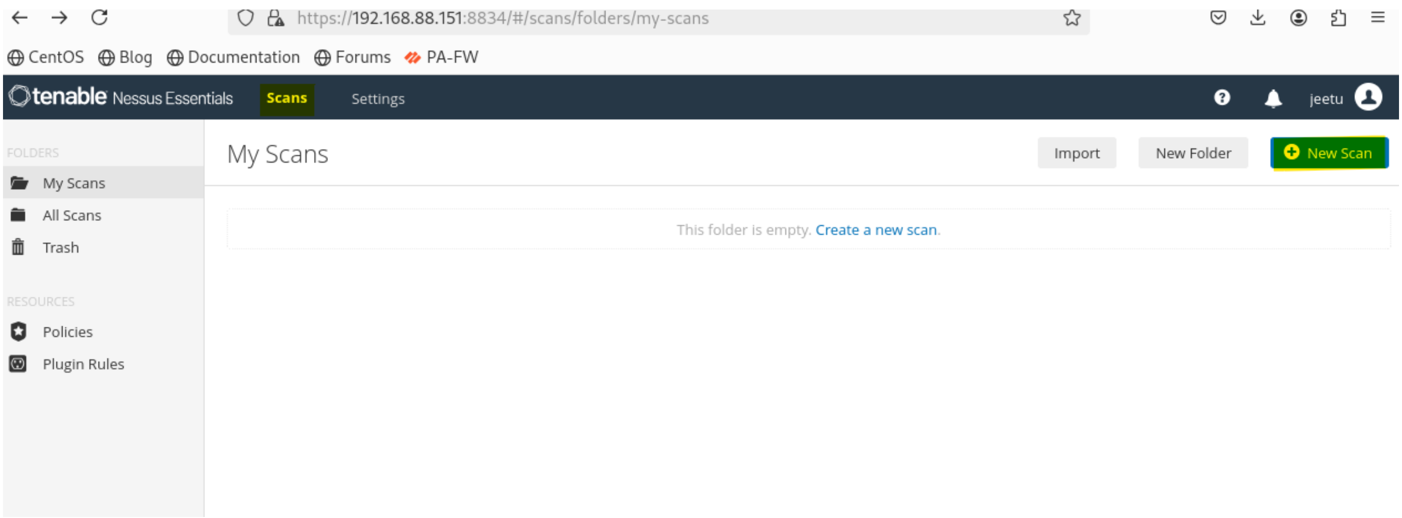


Activation Code: WKZA-DZVE-DLUF-MT57-LBUA

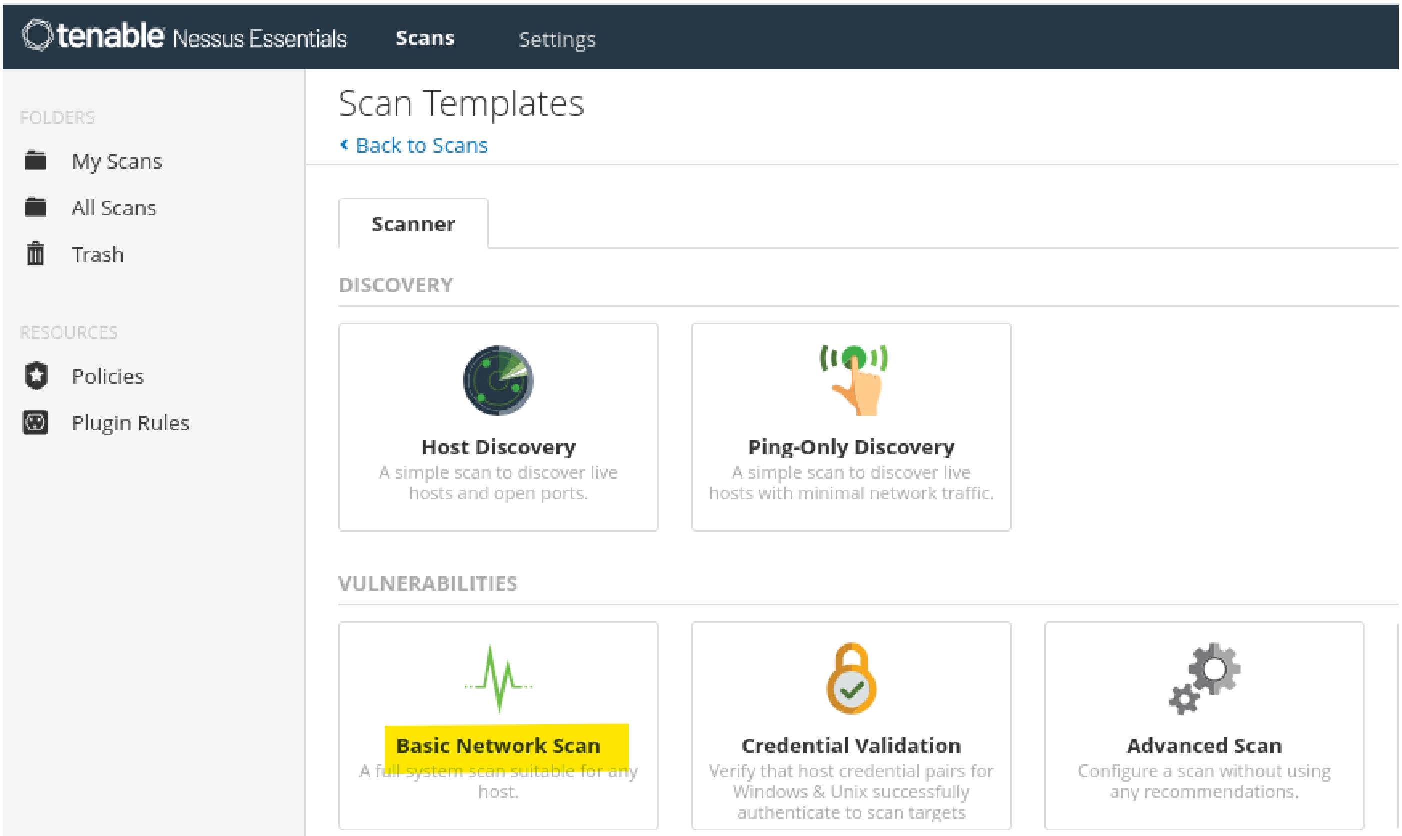




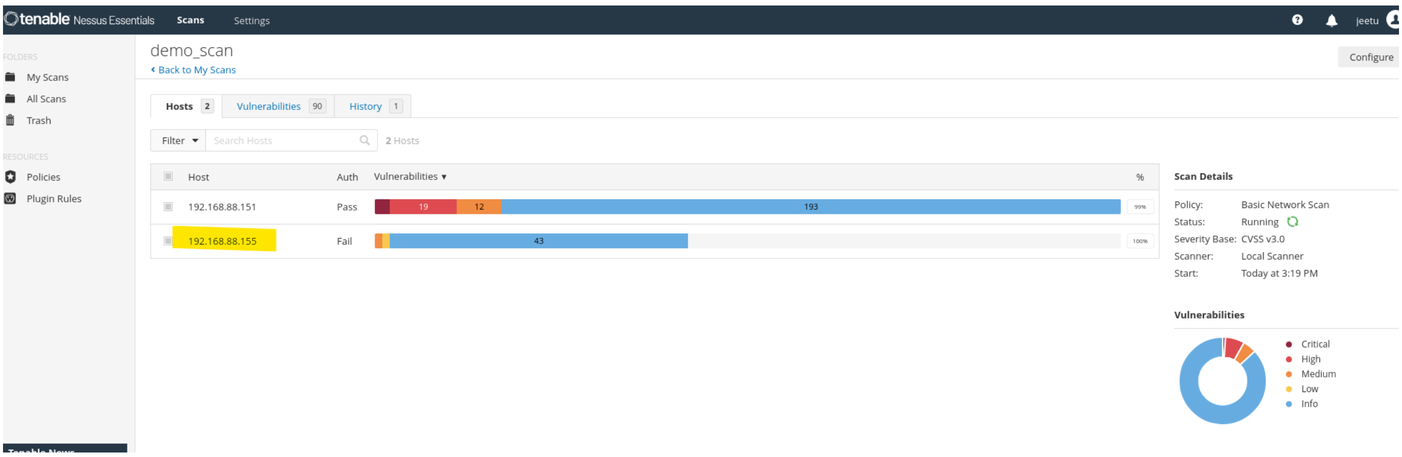
Goto Scan → New Scan



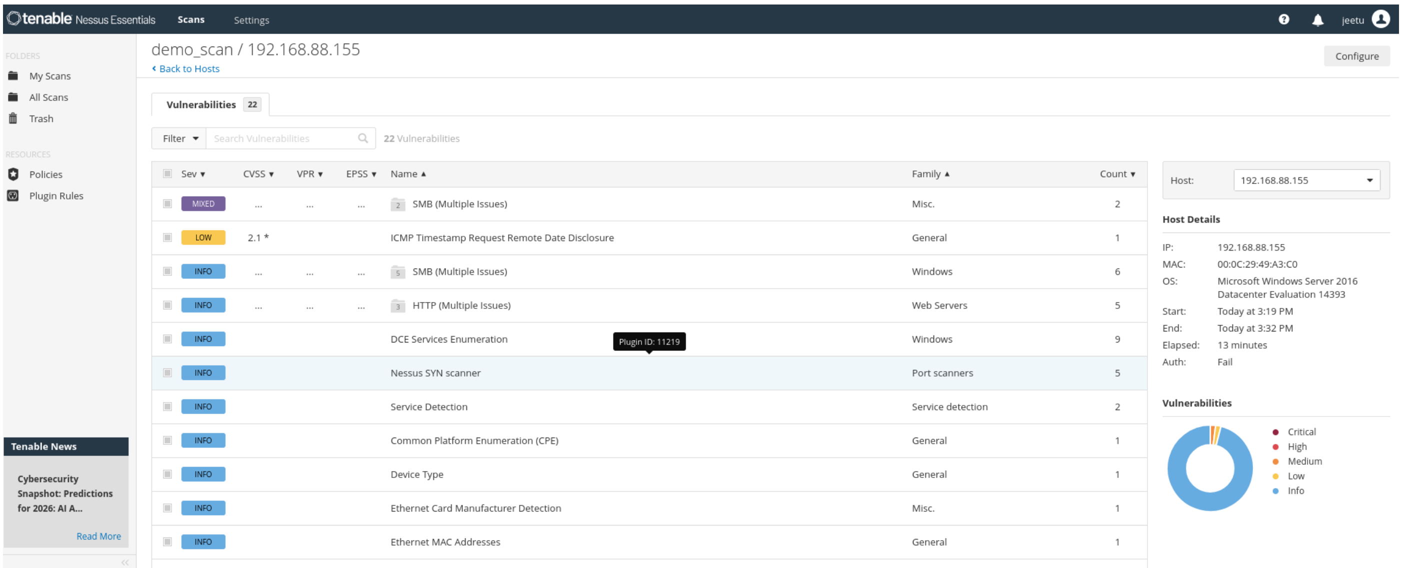
Choose Basic Network Scan



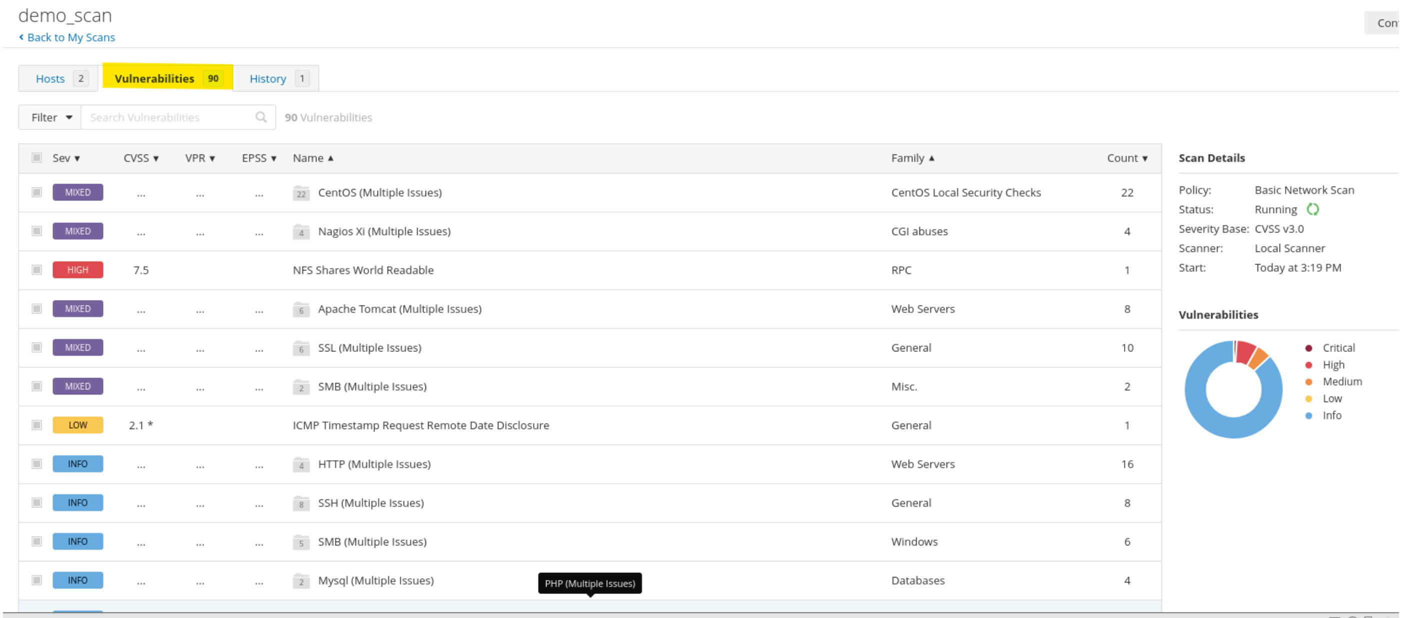
After scanning,



Once you click the target IP address, it will list all the vulnerabilities:



Click on vulnerabilities



What Is Credentialed Scanning (Windows)?

Credentialed scanning allows Nessus to **log in to the Windows system** and perform **deep inspection**, including:

- Missing security patches
- Local vulnerabilities
- Weak configurations
- Installed software inventory
- Registry and policy checks

This provides **far more accurate results** than unauthenticated scans.

Settings → Credentials → Windows

Credential Options

Fill in:

- **Username:** Administrator or DOMAIN\user
- **Password:** Admin password
- **Authentication method:** Password
- **Elevate privileges:** Enabled

Optional:

- Enable **SMB Domain**
- Enable **Start Remote Registry service**

Step 3: Configure the Scan

1. Go to **Scans → New Scan**
2. Select **Basic Network Scan**
3. Enter target IP or hostname
4. Go to **Credentials tab**
5. Add **Windows credentials**
6. Save the scan

Step 8: What Credentialed Scanning Finds That Non-Credentialed Cannot

Area	Non-Cred	Credentialed
Missing patches	❌	✅
Local policies	❌	✅
Registry issues	❌	✅
Installed software	❌	✅
Accurate severity	❌	✅

Students will use OSINT to gather information

OSINT – Open-Source Intelligence, refers to the practice of collecting and analysing publicly available information to identify threats, assess risks and strengthen defences.

Tools

- Using WHOIS database on wipro.com domain.

```
┌──(kali㉿kali)-[~]
└─$ whois wipro.com
   Domain Name: WIPRO.COM
   Registry Domain ID: 2559888_DOMAIN_COM-VRSN
   Registrar WHOIS Server: whois.registrar.amazon
   Registrar URL: http://registrar.amazon.com
   Updated Date: 2025-10-28T11:30:36Z
   Creation Date: 1992-12-08T05:00:00Z
   Registry Expiry Date: 2030-12-07T05:00:00Z
   Registrar: Amazon Registrar, Inc.
   Registrar IANA ID: 468
   Registrar Abuse Contact Email: trustandsafety@support.aws.com
   Registrar Abuse Contact Phone: +1.2024422253
   Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
   Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
   Name Server: NS-1145.AWSDNS-15.ORG
   Name Server: NS-1575.AWSDNS-04.CO.UK
   Name Server: NS-326.AWSDNS-40.COM
   Name Server: NS-659.AWSDNS-18.NET
   DNSSEC: signedDelegation
   DNSSEC DS Data: 31918 13 2 0074B6D159450F1E12E2243EFEA93235A69CBDB77A1CD6A795EEA4F87E7A5C9E
   URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-01-08T14:28:14Z <<<
```

Other useful information:

```
Registrant City: Hayes
Registrant State/Province: Middlesex
Registrant Postal Code: UB3 9TR
Registrant Country: GB
Registrant Phone: +44.1483307527
Registrant Phone Ext:
Registrant Fax: +44.1483304031
Registrant Fax Ext:
Registrant Email: 7649f398-8b17-4de3-9427-9d9020cca728@identity-protect.org
Registry Tech ID: Not Available From Registry
Tech Name: On behalf of wipro.com owner
Tech Organization: Identity Protection Service
Tech Street: PO Box 786
Tech City: Hayes
Tech State/Province: Middlesex
Tech Postal Code: UB3 9TR
Tech Country: GB
Tech Phone: +44.1483307527
Tech Phone Ext:
Tech Fax: +44.1483304031
Tech Fax Ext:
Tech Email: 7649f398-8b17-4de3-9427-9d9020cca728@identity-protect.org
Name Server: NS-659.AWSDNS-18.NET
Name Server: NS-326.AWSDNS-40.COM
Name Server: NS-1575.AWSDNS-04.CO.UK
Name Server: NS-1145.AWSDNS-15.ORG
```

Using dig command for domain Wipro.com for fetching Public IP address.

```
┌──(kali㉿kali)-[~]
└─$ dig wipro.com

; <<>> DiG 9.20.9-1-Debian <<>> wipro.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 63955
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 4096
;; QUESTION SECTION:
;wipro.com.                     IN      A

;; ANSWER SECTION:
wipro.com.              5       IN      A       18.205.78.10

;; Query time: 44 msec
;; SERVER: 192.168.88.2#53(192.168.88.2) (UDP)
;; WHEN: Thu Jan 08 09:30:46 EST 2026
;; MSG SIZE  rcvd: 54
```

Verifying it using PING:

```
C:\Users\Jeetu>ping wipro.com

Pinging wipro.com [18.205.78.10] with 32 bytes of data:
Request timed out.
Request timed out.
Request timed out.
Request timed out.

Ping statistics for 18.205.78.10:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),
```

Using DNSDUMPSTER to gather global information:

https://dnsdumpster.com

ali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

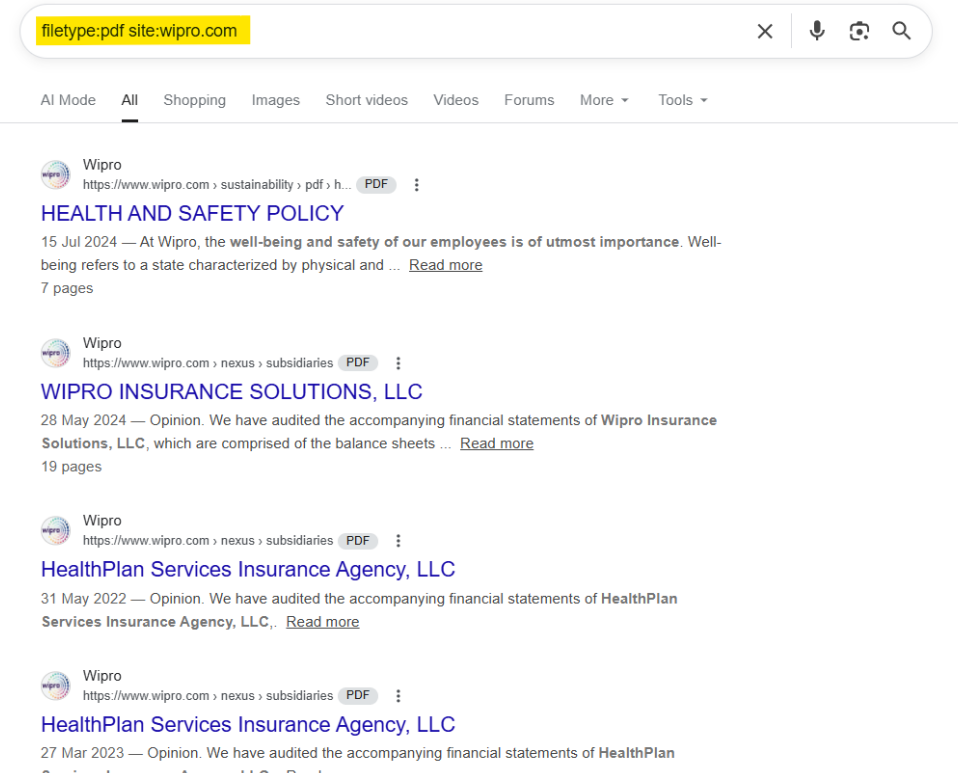
A Records (subdomains from dataset)

Host	IP	ASN	ASN Name	Open Services (from DB)	RevIP
apiaccountservices.wipro.com	203.91.197.71	ASN:23664 203.91.197.0/24	WIPRO-TECH-AS-AP Wipro Technologies, IN India		1
autodiscover.wipro.com	203.91.193.61	ASN:23664 203.91.193.0/24	WIPRO-TECH-AS-AP Wipro Technologies, IN India		1
azeu-p-mcafagnt.wipro.com	52.224.135.151	ASN:8075 52.224.0.0/11	MICROSOFT-CORP-MSN-AS-BLOCK United States		1
base.wipro.com	203.91.193.54	ASN:23664 203.91.193.0/24	WIPRO-TECH-AS-AP Wipro Technologies, IN India		1
blrweb-ext.wipro.com	203.91.193.123	ASN:23664 203.91.193.0/24	WIPRO-TECH-AS-AP Wipro Technologies, IN India		1
cellentvpn.wipro.com	62.154.234.100	ASN:3320 62.154.0.0/15	DTAG Internet service provider operations, DE Germany		1
cloudcar.wipro.com	3.136.185.207 ec2-3-136-185-207.us-east-2.compute.amazonaws.	ASN:16509 3.136.0.0/13	AMAZON-02 United States		2

1. Students will use Google dorks for performing various operations

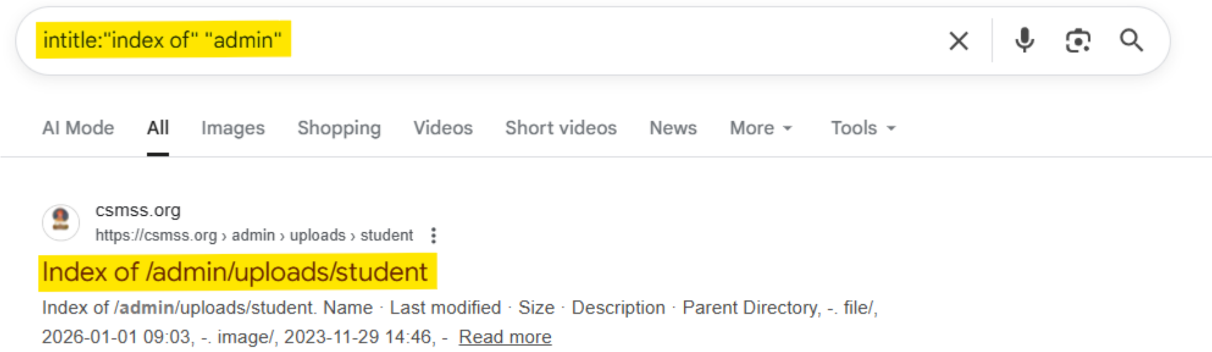
- Google Dorks (or Google hacking queries) are advanced search operators used to uncover hidden information on websites.
- They leverage Google's indexing to find files, misconfigurations, or sensitive data that shouldn't be publicly accessible.

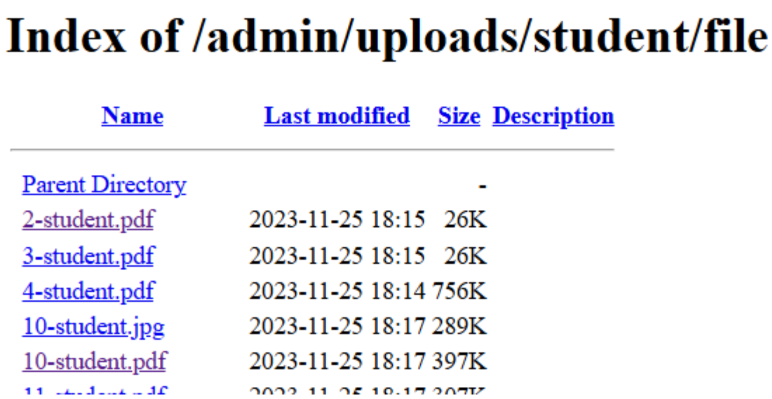
Google Dork: filetype:pdf site:wipro.com



Another example of Google Dork

intitle:"index of" "admin"





Index of /admin/uploads/student/file

Name	Last modified	Size	Description
Parent Directory		-	
2-student.pdf	2023-11-25 18:15	26K	
3-student.pdf	2023-11-25 18:15	26K	
4-student.pdf	2023-11-25 18:14	756K	
10-student.jpg	2023-11-25 18:17	289K	
10-student.pdf	2023-11-25 18:17	397K	

Using Exiftool to get the information of an image, video or PDFs.

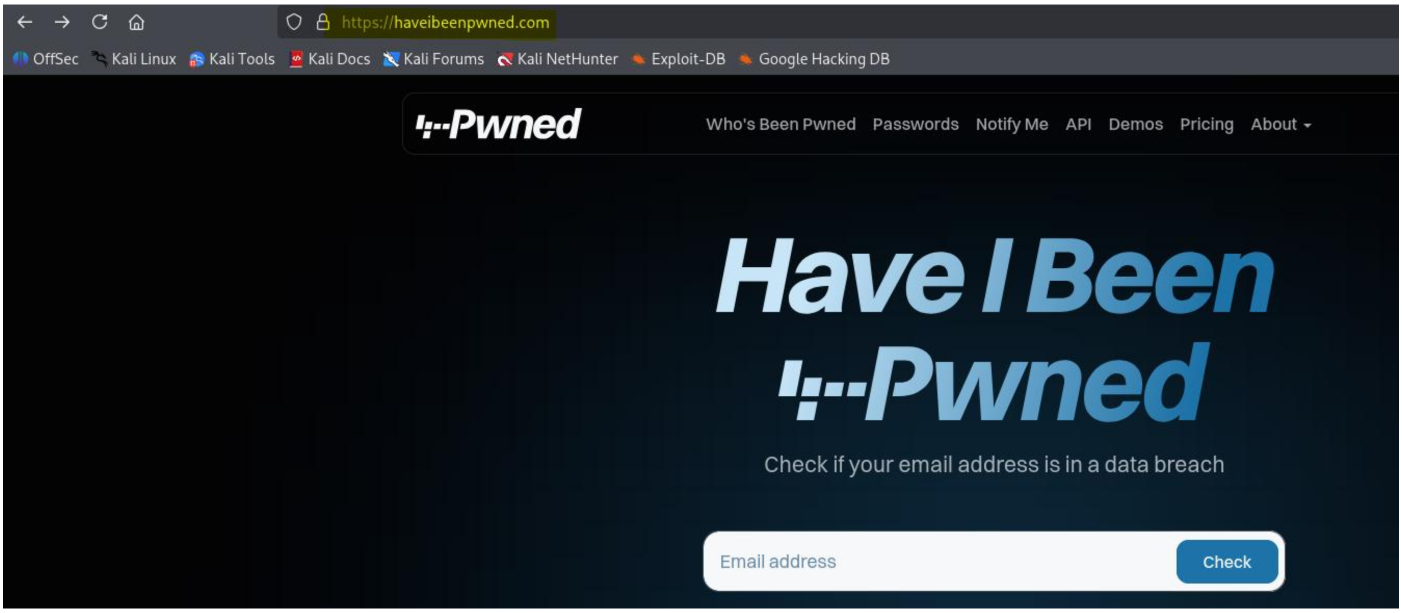
- First you need to download any image from internet. (ex - https://melangeoftales.com/wp-content/uploads/2024/11/AdiyogiAarthy2-2.jpeg)
- Then go to the downloaded location and use “exiftool <filename>.extension”

```
┌──(kali㉿kali)-[~/Downloads]
└─$ exiftool AdiyogiAarthy2-2.jpeg
ExifTool Version Number         : 13.25
File Name                       : AdiyogiAarthy2-2.jpeg
Directory                       : .
File Size                       : 144 kB
File Modification Date/Time     : 2026:01:08 10:02:36-05:00
File Access Date/Time           : 2026:01:08 10:02:36-05:00
File Inode Change Date/Time     : 2026:01:08 10:02:36-05:00
File Permissions                : -rw-rw-r--
File Type                       : JPEG
File Type Extension             : jpg
MIME Type                       : image/jpeg
JFIF Version                    : 1.01
Resolution Unit                 : None
X Resolution                    : 72
Y Resolution                    : 72
Image Width                     : 1024
Image Height                    : 768
Encoding Process                : Progressive DCT, Huffman coding
Bits Per Sample                 : 8
Color Components                : 3
Y Cb Cr Sub Sampling            : YCbCr4:2:0 (2 2)
Image Size                      : 1024x768
Megapixels                      : 0.786
```

I have tried it on an image that I created using Adobe Photoshop CS6

```
┌──(kali㉿kali)-[~/Desktop]
└─$ exiftool jeetu-creative3.jpg
ExifTool Version Number         : 13.25
File Name                       : jeetu-creative3.jpg
Directory                       : .
File Size                       : 1275 kB
File Modification Date/Time     : 2022:08:20 01:25:14-04:00
File Access Date/Time           : 2026:01:08 10:07:26-05:00
File Inode Change Date/Time     : 2026:01:08 10:07:25-05:00
File Permissions                : -rw-------
File Type                       : JPEG
File Type Extension             : jpg
MIME Type                       : image/jpeg
Exif Byte Order                 : Big-endian (Motorola, MM)
Photometric Interpretation      : RGB
Orientation                     : Horizontal (normal)
```

You can check if an email ID has been ever breached or not using “https://haveibeenpwned.com/”



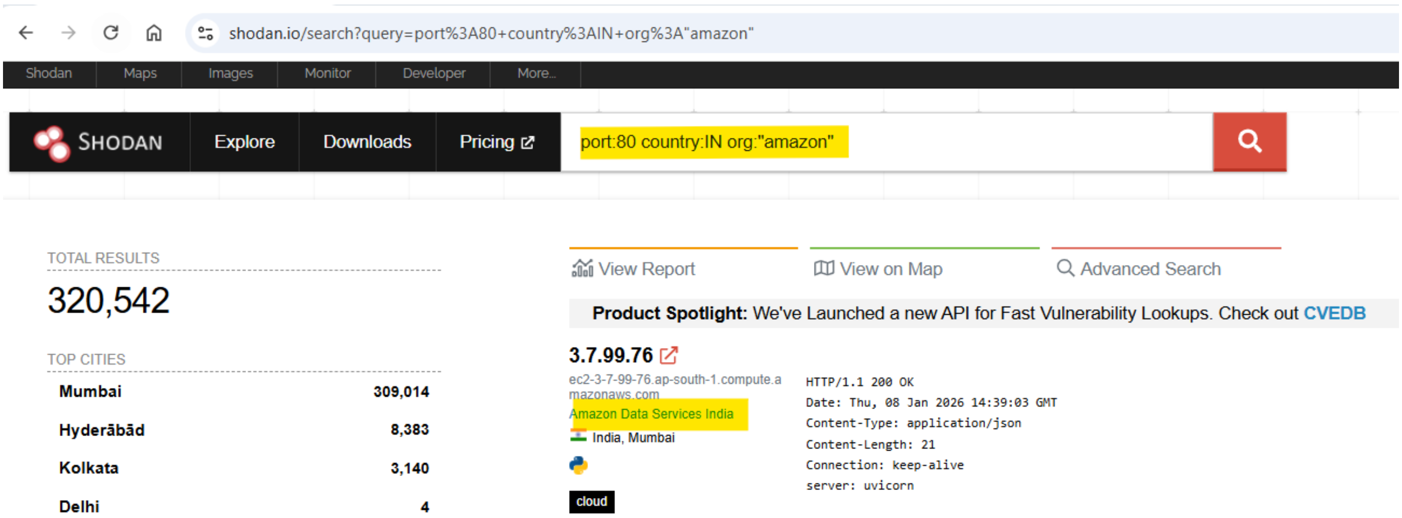
Students will use shodan.io for analysis

- Shodan.io is often called the **"search engine for devices"** because it indexes information about internet-connected systems rather than websites.
- In cybersecurity, especially in **ethical hacking and penetration testing**, it's a powerful OSINT tool.
  - Web search engines, such as Google and Bing, are great for finding websites.
  - But what if you're interested in measuring which countries are becoming more connected?
  - Or if you want to know which version of Microsoft IIS is the most popular?
  - Or you want to find the control servers for malware?
  - Maybe a new vulnerability came out and you want to see how many hosts it could affect?

Set up your environment

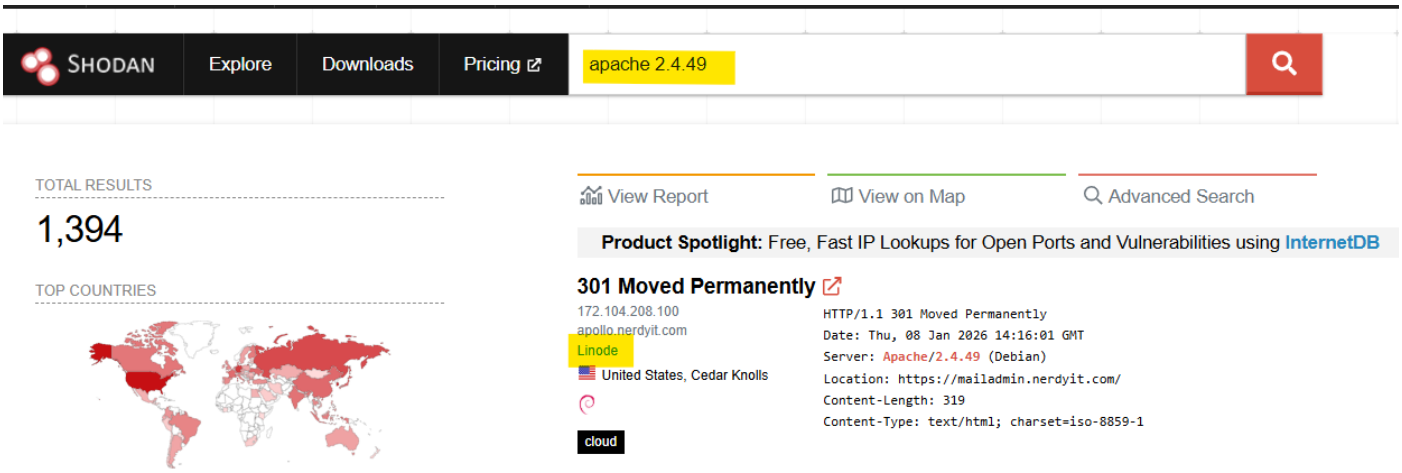
- Create a **Shodan account** (free tier is enough for basic queries).
- Use a **test domain or IP range you own** (or a lab VM with internet exposure).

Query: 'port:80 country:IN org:"amazon"'



Note – You need license for in-depth scanning

Another query "apache 2.4.49"



Tools Summary (Student Safe Tools)

Purpose	**Tool**
Domain info	WHOIS
DNS	dig, nslookup
Infrastructure	Shodan
Tech stack	Wappalyzer
Documents	Google Dorks
Metadata	ExifTool
Social intel	LinkedIn
Code search	GitHub